Office of Information Technology Services

State Capitol P.O. Box 2062
Albany, NY 12220-0062
www.its.ny.gov

New York State Information Technology Policy	**No:** ITS-P26-003
IT Policy: **Vulnerability Disclosure**	**Released:** 10/27/2026
	Issued By: NYS Office of Information Technology Services **Owner:** Chief Information Security Office

1.0 Purpose and Benefits

The New York State (NYS) Office of Information Technology Services (ITS) is committed to ensuring the security of the public by protecting their information. Consistent with recommended best practices, and the ITS' commitment to robust cybersecurity, ITS is establishing a statewide Vulnerability Disclosure Program (VDP). The purpose of this policy is to provide guidance and define and ensure adherence to the VDP as the formal authorized means for external security researchers to engage in the good faith identification of potential security vulnerabilities in publicly available, ITS-owned, -operated, or -managed systems as defined further within this policy.

A VDP serves as a crowdsourced "see something, say something" initiative where an organization allows external security researchers to find and report security vulnerabilities in their systems. This will facilitate ITS's awareness of otherwise unknown vulnerabilities, enhancing ITS's ability to identify and remediate vulnerabilities before malicious actors can exploit them, augmenting existing vulnerability management efforts, and protecting State data and services.

2.0 Authority

Section 103(10) of the State Technology Law provides the Office of Information Technology Services (ITS) with the authority to establish statewide technology policies, including technology and security standards. *Section 2 of Executive Order No. 117*[1], established January 2002, provides the State Chief Information Officer with the authority to oversee, direct and coordinate the establishment of information technology policies, protocols and standards for State government, including hardware, software, security and business re-engineering. Details regarding this authority can be found in NYS ITS Policy, NYS-P08-002 Authority to Establish State Enterprise Information Technology (IT) Policy, Standards and Guidelines.

3.0 Scope

This policy is for security researchers interested in reporting system security vulnerabilities in authorized ITS publicly available systems as per this policy. Any system not expressly listed in this policy is excluded from its scope and is not authorized for research. Additionally, vulnerabilities found in systems owned, operated, or managed by vendors on behalf of ITS, and its supported agencies, fall outside of the scope of this policy, and should be reported directly to the vendor according to their disclosure policy (if any). If a researcher is not sure whether a system is in scope, ITS must be contacted before research begins. Please see Appendix A for authorized systems in scope of this policy.

This policy applies to ITS and ITS-supported agencies ("Client Agencies"). This includes employees of ITS, Client Agencies, and all third parties (such as local governments, consultants, vendors, and contractors) that use or access any Information Technology (IT) Resource for which ITS has administrative responsibility, including systems managed or hosted by third parties on behalf of ITS.

4.0 Information Statement

Vulnerability disclosure is the act of a third party providing vulnerability information to an impacted party, where the third party believes the impacted party is not aware of the information. The third party that performs this act is called the reporter or security researcher. ITS recognizes that coordinating with security researchers will help improve security and bolster the State's digital defenses.

---

1 All references to Executive Order 117 refer to that which was originally issued by Governor George E. Pataki on January 28, 2002 and continued by Executive Order 5 issued by Governor Eliot Spitzer on January 1, 2007, Executive Order 9 issued by Governor David A. Patterson on June 18, 2008, Executive Order 2 issued by Governor Andrew M. Cuomo on January 1, 2011 and Executive Order 6 issued by Governor Kathy Hochul on October 8, 2021.

Vulnerabilities must be submitted in a manner consistent with this policy. Following triage and validation, information submitted to ITS in accordance with this policy may be used to mitigate or remediate internet-accessible systems vulnerabilities. The affected IT Resources will undergo the ITS vulnerability management process, in accordance with NYS-S15-002 Vulnerability Management, to ensure that appropriate actions are taken to reduce the risk of compromise to the confidentiality, integrity, and availability of IT Resources.

4.1 Authorization

All research under this policy must be conducted in good faith. "Good faith" means security research conducted with the intent to follow this policy without any malicious motive and solely for the purpose of testing or investigating a security flaw or vulnerability and disclosing those findings in alignment with the VDP. The security researcher's actions should be consistent with an attempt to improve security and to avoid doing harm including, but not limited to, violations of privacy as defined by State or federal law, or threatening to or actually causing physical damage or harm. Security researchers must comply with all applicable Federal, State, and local laws in connection with the security research activities or other participation in accordance with this policy. If ITS determines that research is conducted in alignment with this policy, it will consider such research to be authorized. ITS will work with the security researcher to understand and resolve the issue in a timely manner.

4.2 Responsibilities

4.2.1 Researchers

Researchers must adhere to all requirements outlined in this policy, including rules of engagement and scope, while conducting research on applicable ITS systems. Under this policy, "research" means activities in which a security researcher:

- Notifies ITS as soon as possible after a real or potential security issue is discovered and, where possible, provides a detailed description or a proof of concept to detail reproduction of vulnerabilities;
- Makes every effort to avoid privacy violations, degradation of user experience, disruption to production systems, and destruction or manipulation of data;
- Only uses exploits to the extent necessary to confirm a vulnerability's presence and does not conduct post-exploitation activities such as data exfiltration, establishing persistence, or "pivoting" to other systems;

- Does not publicly disclose a vulnerability without the explicit written approval of ITS;
- Does not submit a high volume of low-quality reports;
- Does not request compensation for time and materials or vulnerabilities discovered;
- Does not intentionally compromise the privacy or safety of NYS personnel, its residents, or any third parties;
- Does not intentionally compromise the intellectual property or other commercial or financial interests of any State agencies or any third parties; and
- Does not break any applicable law or regulation.

By submitting a report to ITS, researchers warrant that the report and any attachments do not violate the intellectual property rights of any third party and the submitter grants ITS a non-exclusive, royalty-free, world-wide, perpetual license to use, reproduce, create derivative works, and publish the report and any attachments.

Unauthorized Activities

Certain types of information encountered on applicable ITS systems while performing security research within the scope of this policy may be covered under other legal requirements, regulations, or safeguarding measures that supersede the protections and authority of this policy. If a security researcher encounters the following information, they must stop all testing, notify ITS immediately, and refrain from disclosing this information to any third party:

- “Private information” as defined by NYS Technology Law § 208
- “Personal information” as defined by NYS Technology Law § 202 and NYS Public Officers Law § 92
- “Protected health information” as defined by Health Insurance Portability and Accountability Act (HIPAA), at 45 CFR Part 160, mental health information protected under NYS Mental Hygiene Law §33.16, other personally identifiable health information or HIV information protected under NYS Health Law sections §18 or Article 27-F, or substance abuse information protected under federal regulations 42 CFR Part 2
- “Return”, “return information”, and “taxpayer return information” as defined by 26 U.S. Code § 6103

- “Criminal history record information” as defined in 28 CFR Part 20
- Information pertaining to NYS critical infrastructure, as defined in the ITS Glossary
- Proprietary information or trade secrets of companies who are currently or formerly under contract with NYS, or who have provided such information for purposes of procurement or bidding
- Any other information that, if disclosed or accessed, will result in loss of privacy rights or a debilitating impact on security, economic security, public health or safety, or any combination of those matters.

Unauthorized disclosure, dissemination, exfiltration, or reproduction of the aforementioned information types may result in potential legal action and exclusion from further coordinated security research activities with ITS.

Additionally, the following activities and research activities are expressly prohibited:

- Harmful or disruptive behavior
- Social engineering and deception
- Unauthorized access methods
- Password and/or credential attacks
- Unsafe changes or interference

4.2.2 NYS Office of Information Technology Services

NYS ITS is responsible for the central management and execution of this policy, which includes:

- Maintaining this policy and reporting form.
- Receiving, triaging, and validating vulnerability submissions from external security researchers.
- Determining the severity rating of validated vulnerabilities.
- Using best efforts to remediate validated vulnerabilities in ITS-managed systems according to severity-based timelines established and communicated. In the event remediation is not possible, security exceptions must be sought following the established processes.

- Communicating validated vulnerability reports to the affected Client Agencies for remediation.
- Tracking remediation progress across Client Agencies.
- Coordinating validation of remediation actions.
- Providing subject matter expertise and guidance to Client Agencies upon request.
- Maintaining overall program documentation and reporting.

ITS may modify the terms of this policy or terminate the policy at any time in its sole and absolute discretion. For vulnerabilities disclosed to ITS outside the scope of this policy, to the extent practicable, ITS will notify appropriate officials of the affected governmental entity and turn over the vulnerability report.

4.2.3 Client Agencies

All vulnerability submissions received by ITS within the scope of this policy will be triaged and validated by ITS. Unless otherwise expressly exempted, all Client Agencies who are covered by the scope of this policy are responsible for:

- Acknowledging receipt of each vulnerability report shared with them by ITS within 2 business days by responding to the communication delivering it;
- Actively coordinating remediation planning, execution, and validation efforts with ITS when requested. This includes providing necessary information for risk assessment and remediation tracking;
- Using best efforts to remediate validated vulnerabilities in Client Agency-managed systems according to severity-based timelines established and communicated. ITS will provide specific remediation targets based on the final severity assessment (Critical, High, Medium, Low). In the event remediation is not possible, Client Agencies must seek security exceptions following the established processes;
- Notifying ITS upon completion of remediation actions and cooperating with ITS to validate the effectiveness of the remediation; and
- Collaborating with ITS to implement technical best practices that signal the availability of the VDP (e.g., adding a link to the VDP within website footers of covered websites; etc.).

4.3 No Compensation

ITS does not offer financial rewards or compensation for vulnerability submissions and/or participation. The VDP is intended to facilitate responsible disclosure and improve state cybersecurity, and participation is voluntary. Recognition may be offered at the discretion of ITS, but submission does not imply entitlement to any reward or acknowledgment.

4.4 Disclosure Guidelines

ITS follows a coordinated disclosure process. Security researchers must submit identified vulnerabilities at Vulnerability Reporting in adherence to this policy. By participating, security researchers agree not to publicly disclose a vulnerability until ITS has provided explicit written approval.

There is no automatic release date for submitted vulnerabilities or reports. ITS will decide if, when, and what information may be shared. Unauthorized disclosure may result in removal from the program and potential legal action. Proof-of-concept material must not be posted to public platforms.

Early public disclosure may put the public or systems at risk. Responsible communication ensures vulnerabilities are addressed safely and effectively. If a security researcher shares their contact information with a vulnerability report submission, ITS commits to coordinating with the security researcher in a timely manner.

4.5 Confidentiality

Security researchers may submit reports anonymously or security researchers may provide contact information. ITS may contact security researchers to clarify reported vulnerability information or other technical interchange. While a vulnerability disclosure report may be shared with other state government entities or trusted third parties, ITS agrees not to publicly share the identity or contact information of the security researcher without express consent unless required to do so by law.

4.6 Legal Disclaimer

If researchers conduct vulnerability disclosure activities in accordance with the restrictions and guidelines set forth in this policy, (1) ITS will not recommend any law enforcement or civil actions related to such activities, and (2) in the event of any law enforcement or civil action brought in connection with research activities, ITS will take steps to make known its view that the researchers activities were conducted pursuant to and in compliance with this policy.

ITS does not authorize, permit, or otherwise allow (expressly or impliedly) any person, including any individual, group of individuals, consortium, partnership, or any other business or legal entity, to engage in any security research or

vulnerability or threat disclosure activity on or affecting ITS systems that is inconsistent with this policy or the law. If a researcher engages in any activities that are inconsistent with this policy or applicable law, the researcher may be subject to criminal and/or civil liabilities.

To the extent that any security research or vulnerability disclosure activity involves the networks, systems, information, applications, products, or services of a non-NYS entity (e.g., federal, state, local, or Tribal governments; private sector companies or persons; employees or personnel of any such entities; or any other such third party), that third party may independently determine whether to pursue legal action or remedies related to such activities.

This policy does not in any way limit the authority of the United States Attorneys or other components of the DOJ or the New York State Attorney General or Department of Law to pursue legal action. Nor will actions taken in connection with this policy or program shield an individual or entity from prosecution or consequences for any violations of law, regardless of intent or awareness of noncompliance with any law and/or policy.

5.0 Compliance

This policy shall take effect upon publication. Compliance is required with all ITS policies and standards. ITS may amend or terminate its policies and standards at any time; compliance with amended policies and standards is required.

6.0 Definitions of Key Terms

Except for terms defined in this policy, all terms shall have the meanings found in the ITS Glossary.

7.0 Contact Information

Submit all inquiries and requests for future enhancements to the policy owner at:

Chief Information Security Office
Reference: ITS-P26-003
NYS Office of Information Technology Services
31 British American Blvd.,
Latham, NY 12110
Telephone: (518) 242-5200
Email: CISO@its.ny.gov

Statewide technology policies, standards, and guidelines may be found on the ITS Policies page.

8.0 Revision History

This policy should be reviewed consistent with the requirements set forth in ITS-P24-003 Process for Establishing Information Technology Policies, Standards and Guidelines.

Date	Description of Change	Reviewer
10/27/2026	Original Policy Release	Chris DeSain, Chief Information Security Officer

9.0 Related Documents

Cybersecurity and Infrastructure Security Agency | Vulnerability Disclosure Policy Template

NIST SP 800-216 Recommendations for Federal Vulnerability Disclosure Guidelines

NYS-S15-001 Patch Management

NYS-S15-002 Vulnerability Management

Appendix A

The following agencies, and related systems, sites, and subdomains that are in-scope for the New York State Office of Information Technology Services' (ITS) Vulnerability Disclosure Program:

Department of Labor	Office for the Aging
Justice Center for the Protection of People with Special Needs	Office for People with Developmental Disabilities
NYS Higher Education Services Corporation	Department of Civil Service
Office of Employee Relations	Public Employee Relations Board
State Liquor Authority	Homes and Community Renewal
Department of Taxation and Finance	Division of Tax Appeals
Department of Environmental Conservation	Workers' Compensation Board
Office of Children and Family Services	Council on Children and Families
Gaming Commission	Division of Human Rights
Office of the Medicaid Inspector General	Commission on Ethics and Lobbying in Government
Department of Veterans' Services	Financial Controls Board
Commission on Prosecutorial Conduct	Division of State Police
Department of State	Department of Motor Vehicles

Department of Agriculture and Markets	Office of Cannabis Management
Department of Public Service	Office of General Services
Office of Temporary and Disability Assistance	Division of Budget
Office of Parks, Recreation, and Historic Preservation	Adirondack Park Agency
Department of Corrections and Community Supervision	Department of Transportation
Division of Homeland Security and Emergency Services	Department of Health
Office of Mental Health	Office of Addiction Services and Supports
Division of Criminal Justice Services	Office for the Prevention of Domestic Violence
Office of Victim Services	State Commission on Correction

- All websites and web applications belonging to the ny.gov domain
- All publicly accessible systems within NYS public IP space
- All websites and web applications where the Vulnerability Disclosure Program participation notification appears

The following systems, sites, or subdomains are restricted from active vulnerability discovery, and are considered out-of-scope for the VDP program:

- Operational technology (OT) / industrial control systems (ICS) managed by ITS

Any systems, sites, or subdomains not expressly listed above are excluded from scope and are not authorized for security research. Additionally, vulnerabilities

found in systems from ITS vendors fall outside of the VDP scope and should be reported directly to the vendor according to their disclosure policy (if any). If a researcher isn't sure whether a system is in scope or not, ITS must be contacted before research begins.